

Hochschule [Name der Hochschule]

Modul: WPM Sicherheit & Webanwendungen

Einsendeaufgabe 1 – Konkretisierung der Aufgabenstellung

Thema:

Sicherheitsaudit für KI-basierte Anwendungen – Anforderungen, Vorgehen und Relevanz für KRITIS-Unternehmen

Name: [Vorname Nachname]

Matrikelnummer: [Matrikelnummer]

Datum: [TT.MM.JJJJ]

1. Themenbeschreibung und Fokussierung

Künstliche Intelligenz (KI) wird zunehmend in kritischen Infrastrukturen eingesetzt, beispielsweise bei Energieversorgern, im Gesundheitswesen oder im Finanzsektor. Damit steigen auch die Anforderungen an Sicherheit, Transparenz und Nachvollziehbarkeit solcher Systeme.

Im Gegensatz zu einem technischen Penetrationstest steht beim Sicherheitsaudit die Bewertung organisatorischer, prozessualer und regulatorischer Sicherheitsaspekte im Vordergrund. In diesem Projekt liegt der Fokus auf der theoretischen und konzeptionellen Ausarbeitung, also darauf, wie ein Sicherheitsaudit für KI-basierte Anwendungen strukturiert sein sollte und welche rechtlichen und normativen Grundlagen dabei relevant sind. Eine praktische Umsetzung (z. B. Durchführung eines konkreten Audits oder technische Tests) ist nicht vorgesehen.

2. Forschungsfrage

Wie kann ein Sicherheitsaudit für KI-basierte Anwendungen theoretisch konzipiert werden, um regulatorische Anforderungen und KI-spezifische Risiken systematisch zu adressieren?

3. Teilfragestellungen

1. Welche gesetzlichen, normativen und branchenspezifischen Anforderungen (z. B. EU AI Act, BSI IT-Grundschutz, ISO 27001, NIS-2) sind für Sicherheitsaudits von KI-Systemen relevant?
2. Wie unterscheiden sich Audits für KI-basierte Anwendungen von klassischen IT-Sicherheitsaudits?
3. Wie kann ein Auditprozess in bestehende Sicherheits- und Compliance-Strukturen eines Unternehmens eingebettet werden?
4. Welche typischen Sicherheitsrisiken entstehen im Zusammenhang mit KI (z. B. Datenmanipulation, Modelllecks, Bias) und wie sollten diese im Rahmen eines Audits bewertet werden?

4. Geplantes Ergebnis (Deliverable)

Das geplante Ergebnis ist ein theoretisches Konzeptpapier. Dieses soll folgende Punkte enthalten:

- Überblick über relevante Normen und Regularien für KI-Sicherheitsaudits
- Zusammenfassung zentraler Auditprinzipien und Prozessphasen
- Vorschlag eines Rahmenmodells oder Vorgehensschemas für Audits von KI-Anwendungen
- Diskussion der besonderen Herausforderungen und Risiken im KI-Kontext

5. Bezug zu OWASP Top 10

Für das Thema sind insbesondere folgende OWASP-Kategorien relevant:

A01: Broken Access Control – Zugriff auf Trainingsdaten, Modelle oder APIs

A02: Cryptographic Failures – Schutz sensibler Daten und Modelle

A05: Security Misconfiguration – Fehlkonfiguration von ML-Umgebungen oder Cloud-Diensten

ML01: Data Poisoning – Manipulation von Trainingsdaten

ML02: Model Theft / Extraction – Abfluss von Modellen durch API-Zugriffe

ML08: Bias & Fairness – Prüfung auf unfaire oder diskriminierende Entscheidungen

6. Konsistenzprüfung

Die Forschungsfrage, Teilfragestellungen und das geplante Deliverable sind konsistent: Die Forschungsfrage zielt auf ein theoretisches Auditkonzept ab. Die Teilfragestellungen beleuchten rechtliche, organisatorische und risikobasierte Dimensionen. Das Deliverable ist ein Konzeptpapier, das alle theoretischen Aspekte bündelt und ohne praktische Umsetzung auskommt.

Kurzfazit

Das Projekt untersucht konzeptionell, wie Sicherheitsaudits für KI-Systeme gestaltet werden sollten, um regulatorischen und sicherheitstechnischen Anforderungen zu entsprechen. Der Fokus liegt auf der theoretischen Analyse und Strukturierung des Auditverfahrens – ohne praktische Umsetzung oder technische Tests.